HARDENING WINDOWS 11 - GUI MANUAL

Aplicação manual dos mesmos 25 itens do script PowerShell disponibilizados no github.com/projetoroot

Autor: Diego Costa - Windows 11 Pro 23H2 – 2026

O script de hardening e o manual técnico que preparei foram inspirados diretamente nas recomendações do CIS Microsoft Windows 11 Enterprise Benchmark versão 5.0.0. Peguei os controles de segurança dali como base para configurar o SO de forma bem segura, tipo desabilitar serviços desnecessários, reforçar senhas e limitar privilégios de usuário – tudo aquilo que o benchmark recomenda para minimizar riscos reais, como exploits conhecidos ou acessos não autorizados.

A ideia principal foi pegar essas diretrizes, que são bem formais e técnicas, e transformá-las em algo prático para o dia a dia. Criei duas opções: uma automatizada, via script em PowerShell que roda tudo de uma vez (perfeito para deploy em massa ou testes rápidos), e outra manual, passo a passo pela interface gráfica do Windows, com dicas para quem prefere ir configurando aos poucos. Isso é especialmente útil para empresas que não têm Active Directory ou GPOs centralizadas – vocês podem aplicar os mesmos padrões de segurança localmente, sem depender de uma infraestrutura grande.

No fim das contas, o resultado é um sistema com superfície de ataque bem menor: serviços controlados, políticas locais mais rígidas e um hardening geral que segue as melhores práticas internacionais. Já testei em ambientes reais e vi diferença na estabilidade e na proteção contra ameaças comuns.

1. Firewall ativo + Bloqueio TCP 445 (SMB Inbound)

O que faz	Ativa Firewall em todos os perfis e bloqueia conexões de entrada na porta 445.
O que previne	WannaCry, EternalBlue, movimento lateral via SMB.
Impacto ao ativar/desativar	Bloqueia apenas entrada SMB. Acesso a \servidor\share continua funcionando.
Como fazer manualmente	1. Configurações → Privacidade e Segurança → Segurança do Windows. 2. Firewall e proteção de rede → Ativar em Domínio, Privado e Público. 3. Configurações avançadas → Regras de Entrada → Nova Regra. 4. Porta → TCP → Porta local específica 445. 5. Bloquear conexão → Aplicar a todos perfis → Nomear SMBBlock445.

2. NTLMv2 obrigatório (LmCompatibilityLevel=5)

O que faz	Forca autenticação NTLMv2 ou Kerberos.
O que previne	Pass-the-hash e quebra de NTLMv1.
Impacto ao ativar/desativar	Sistemas antigos que usam NTLMv1 podem falhar autenticação.
Como fazer manualmente	Win+R → secpol.msc → Políticas Locais → Opções de Segurança → Segurança de rede: Nível de autenticação LAN Manager → Enviar somente NTLMv2. Recusar LM e NTLM.

3. WDigest desabilitado

O que faz	Impede armazenamento de senha em texto claro na memória.
O que previne	Dump de credenciais via Mimikatz.
Impacto ao ativar/desativar	Nenhum impacto visível para usuário comum.
Como fazer manualmente	Win+R → regedit → HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest → Valor UseLogonCredential = 0 (DWORD).

4. LLMNR desabilitado

O que faz	Desativa resolução multicast local.
O que previne	Responder, spoofing .local.
Impacto ao ativar/desativar	Equipamentos que dependem de descoberta local podem parar de resolver nomes.
Como fazer manualmente	Win+R → gpedit.msc → Configuração do Computador → Modelos Administrativos → Rede → Cliente DNS → Desativar resolução de nome multicast → Habilitado.

5. Restrict Anonymous = 1

O que faz	Bloqueia sessões anônimas SMB/RPC.
O que previne	Enumeração de usuários via NULL session.
Impacto ao ativar/desativar	Ferramentas antigas de inventario podem parar de listar recursos.
Como fazer manualmente	secpol.msc → Políticas Locais → Opções de Segurança → Acesso a rede: Não permitir enumeração anônima de contas e compartilhamentos → Habilitado.

6. LSASS Protected Process

O que faz	Protege LSASS contra dump por processos não assinados.
O que previne	Dump de credenciais e injeção de código.
Impacto ao ativar/desativar	Ferramentas de diagnostico não assinadas não acessam LSASS.
Como fazer manualmente	secpol.msc → Opções de Segurança → Executar LSASS como processo protegido → Habilitado. Reiniciar obrigatório.

- Caso não apareça no secpol fazer:
  regedit → HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa→
  Criar DWORD RunAsPPL = 1

7. Desabilitar RDP Inbound

O que faz	Impede conexões remotas recebidas via porta 3389.
O que previne	Bruteforce RDP e BlueKeep.
Impacto ao ativar/desativar	Você não poderá acessar este PC via Area de Trabalho Remota.
Como fazer manualmente	Configurações → Sistema → Area de Trabalho Remota → Desativar. Ou Painel de Controle → Sistema → Configurações Remotas → Desmarcar permitir conexões.

8. UAC nível máximo

O que faz	Forca solicitação de confirmação para elevação administrativa.
O que previne	Elevação silenciosa de privilégios.
Impacto ao ativar/desativar	Mais prompts de confirmação para admins.
Como fazer manualmente	Painel de Controle → Contas de Usuário → Alterar configurações de Controle de Conta de Usuário → Mover controle para o nível máximo.

9. Desativar Autorun todos drives

O que faz	Bloqueia execução automática de mídias.
O que previne	Worms USB como Conficker.
Impacto ao ativar/desativar	Nenhum programa abrira automaticamente ao inserir USB.
Como fazer manualmente	gpedit.msc → Modelos Administrativos → Componentes do Windows → AutoPlay ou (Política de Reprodução Automática) → Desativar reprodução automática → Habilitado → Todos os drives.

10. Conta Guest desabilitada

O que faz	Remove conta padrão sem senha.
O que previne	Acesso local não autenticado.
Impacto ao ativar/desativar	Conta Guest não poderá ser utilizada.

Como fazer manualmente	Win+R → lusrmgr.msc → Usuários → Guest → Propriedades → Conta desativada.

11. Auditoria Logon e Criação de Processo

O que faz	Habilita eventos 4624, 4625 e 4688.
O que previne	Falta de rastreabilidade forense.
Impacto ao ativar/desativar	Aumento do tamanho dos logs de segurança.
Como fazer manualmente	secpol.msc → Políticas Locais → Política de Auditoria → Auditar eventos de logon → Sucesso e Falha. Auditar rastreamento de processo → Sucesso e Falha.

12. PowerShell Script Block Logging

O que faz	Registra todos comandos PowerShell.
O que previne	Execução oculta via -enc e bypass simples.
Impacto ao ativar/desativar	Aumento de logs no Event Viewer.
Como fazer manualmente	gpedit.msc → Componentes do Windows → Modelos Administrativos → Windows PowerShell → Ativar registro de bloco de script → Habilitado.

13. Log de linha de comando 4688

O que faz	Registra argumentos completos dos processos.
O que previne	Execução maliciosa escondida em parâmetros.
Impacto ao ativar/desativar	Logs mais detalhados no Security.
Como fazer manualmente	regedit → HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Audit → Criar DWORD ProcessCreationIncludeCmdLine_Enabled = 1.

14. RemoteRegistry desabilitado

O que faz	Impede alteração remota do registro.
O que previne	Exploração remota via registry.

Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Registro Remoto → Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar.

15. WebClient desabilitado

O que faz	Desativa WebDAV.
O que previne	Phishing via caminho UNC malicioso.
Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Cliente da Web → Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar.

16. Print Spooler desabilitado

O que faz	Remove serviço de impressão remoto.
O que previne	PrintNightmare.
Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Spooler de Impressão → Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar.

17. LanmanServer desabilitado

O que faz	Remove compartilhamentos administrativos SMB.
O que previne	Movimento lateral via C$.
Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Server → Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar.

18. Windows Search desabilitado

O que faz	Desativa indexação.

O que previne	Explorações locais históricas.
Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Windows Search→ Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar.

19. BITS desabilitado

O que faz	Remove download em background como SYSTEM.
O que previne	Malware baixando payload silencioso.
Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Serviço de Transferência Inteligente em Segundo Plano → Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar. • Esta opção desativa o Windows update automático, manter ativado em caso que seja de interesse!

20. Telnet Server desabilitado

O que faz	Remove protocolo plaintext.
O que previne	Captura de senha em rede.
Impacto ao ativar/desativar	Serviço não iniciara automaticamente.
Como fazer manualmente	Win+R → services.msc → Telnet → Duplo clique → Tipo de Inicialização: Desativado → Parar → Aplicar. • Na maioria das instalações o Telnet não vem habilitado, então esse processo é só um reforço para manter desativado.

21. Defender ASR - Bloqueio de Execução Web/Office

O que faz	Reduz superfície de ataque bloqueando execução de arquivos suspeitos do Office e

	web.
O que previne	Execução de malware via arquivos HTML, LNK e Office.
Impacto ao ativar/desativar	Macros legítimas ou automações podem ser bloqueadas.
Como fazer manualmente	Win → Segurança do Windows → Controle de aplicativos e navegador → Proteção contra exploits → Configurações de Exploit Protection → Ativar regras de ASR relacionadas a Office e arquivos da web.
# PowerShell $rules = @("D4F940AB-401B-4EFC-AADC-AD5F3C50688A", # Bloquear execução de conteúdo da web "3B576869-A4EC-4529-8536-B80A7769E899", # Bloquear processos filho do Office "BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550", # Bloquear conteúdo executável de email/webmail "5BEB7EFE-FD9A-4556-801D-275E5FFC04CC" # Bloquear scripts ofuscados) Add-MpPreference -AttackSurfaceReductionRules_Ids $rules ` -AttackSurfaceReductionRules_Actions Enable	• Talvez essas opções não sejam exibidas na interface do Windows, depende da versão, caso não mostre execute o powershell ao lado como Administrador.

22. Mark of the Web (SaveZoneInformation)

O que faz	Mantém identificação de zona em arquivos baixados.
O que previne	Execução de arquivos baixados sem restrições.
Impacto ao ativar/desativar	Arquivos baixados podem ser executados sem aviso se desativado.

Como fazer manualmente	Win+R → regedit → HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Attachments → Novo Valor DWORD: SaveZoneInformation = 1

23. SmartScreen RequireAdmin

O que faz	Obriga validação administrativa para executáveis não reconhecidos.
O que previne	Execução de malware sem verificação reputacional.
Impacto ao ativar/desativar	Pode gerar prompts adicionais.
Como fazer manualmente	Win+R → regedit → HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\ → Novo Valor String: SmartScreenEnabled = RequireAdmin

24. Software Restriction Policy - Bloqueio Temp e Downloads

O que faz	Impede execução direta de arquivos em diretórios de alto risco.
O que previne	Execução de malware em Downloads ou AppData\Temp.
Impacto ao ativar/desativar	Pode bloquear instaladores legítimos nessas pastas.
Como fazer manualmente	Win+R → secpol.msc → Políticas de Controle de Software → Nova Política de Restrição de Software → Regras adicionais → Nova Regra de Caminho → %USERPROFILE%\Downloads*.exe %USERPROFILE%\Downloads*.bat %USERPROFILE%\Downloads*.cmd %USERPROFILE%\Downloads*.ps1 %USERPROFILE%\AppData\Local\Temp*.exe ... Nível de segurança: **Não permitido**

25. Windows Update Automático

O que faz	Garante aplicação automática de patches de segurança.
O que previne	Exploração de vulnerabilidades conhecidas.
Impacto ao ativar/desativar	Atualizações automáticas podem gerar reinícios automáticos.
Como fazer manualmente	Configurações → Atualização e Segurança → Windows Update → Opções avançadas → Receber atualizações automaticamente = Ativado.

Reinício Obrigatório

Após aplicar todos os 25 itens, reinicie o sistema.

Verifique logs em eventvwr e status dos serviços em services.msc.